

Security and Code Health Closure Report

Final engineering handover for the AsliLearn backend and frontend repositories

REPORT STATUS

READY FOR HANDOVER

Executive result

The reported source-code security work is complete, the frontend strict TypeScript check is clean, and the production frontend build succeeds. Remaining credential rotation tasks require the client's infrastructure access and are intentionally listed as client actions, not unresolved code defects.

Frontend type errors	Backend tests	Client actions
175 -> 0	103 passed	Required
Strict checking remains enabled.	0 failed; 1 DB integration skip.	Rotate exposed credentials after handover.

Repository delivery references

Repository	Code commit	Purpose
aslilearnai-hyd/Aslilearn-backend	8edd24b3	Credential hygiene, source scanning, CORS, deletion safeguards, runtime hardening
aslilearnai-hyd/Aslilearn-frontend	894bba0c	Strict typecheck closure and reported regular-expression hardening

Important: no passwords, connection strings, tokens, or secret values are reproduced in this report.

Completed source-code remediation

Items below are implemented in code and verified in the current handover branches.

STATUS	AREA	COMPLETED WORK
COMPLETE	Credential removal	Removed embedded MongoDB and maintenance credentials from current source files. Maintenance utilities now require environment-provided values.
COMPLETE	Admin password handling	Admin email and replacement password are accepted only from environment variables. Password values are no longer printed. The login verification script is read-only and cannot reset a password.
COMPLETE	Environment template	Expanded .env.example with safe placeholders and operational descriptions. No live values were added.
COMPLETE	Automated secret scan	Added a tracked-source regression test that rejects MongoDB URIs with embedded credentials and verifies maintenance scripts remain environment-only.
COMPLETE	CORS and request boundaries	Production origins use an explicit allowlist; the plain-HTTP production origin and reflective preflight handling were removed.
COMPLETE	Regular-expression safety	Replaced the reported nested-repeat patterns across frontend, mobile, and backend normalization code, and added bounded-time regression coverage.
COMPLETE	Data deletion safeguards	Permanent school deletion is blocked. Normal removal remains recoverable soft deactivation.
COMPLETE	Runtime hardening	The optional Python server binds to localhost by default. Android release cleartext traffic and application-data backup are disabled.

Existing admin login after credential removal

Yes - removing credentials from source code does not delete the super-admin account or change its stored password hash in MongoDB. The existing login continues to work unless the database record or password is deliberately changed. The client should still rotate any password that was previously exposed or shared.

Frontend TypeScript closure

Strict type checking was retained and corrected rather than bypassed.

CHECK	BEFORE	FINAL	RESULT
npm run check	175 reported errors	0 errors	PASS
npm run build	Build was not the error source	Production bundle completed	PASS
Compiler policy	Stale target/cache plus real defects	ES2022 target; strict=true; noEmit=true	ENFORCED

What was fixed

- Corrected incomplete state shapes, optional-value handling, callback contracts, and missing local interfaces.
- Added local declarations for react-katex and removed broken references to an absent shared schema package.
- Aligned exam, analytics, timetable, content, and video-scheduling types with their actual runtime data.
- Kept strict compiler checks enabled and removed stale incremental-cache behavior that produced misleading legacy-target errors.
- Excluded five confirmed unreachable legacy demo/player files from the production typecheck. They are not imported by the application and one depended on an uninstalled hls.js package.

Excluded legacy files

```
src/components/AnimatedExamReviewModal.tsx
src/components/ExamModalIntegration.tsx
src/components/stream-player.tsx
src/components/video-player.tsx
src/pages/video-lectures.tsx
```

These exclusions do not remove a routed screen or imported production module. If the client later revives any of them, it should be restored to the compiler scope and repaired before use.

Client actions required after handover

These actions cannot be completed safely in source code because they require the client's cloud accounts, secret manager, and production deployment access.

PRIORITY	CLIENT MUST ROTATE OR CONFIGURE	ACCEPTANCE CHECK
1 - IMMEDIATE	MongoDB Atlas database-user password used by the exposed connection string	Old URI fails; new MONGO_URI succeeds only from approved environments
2 - IMMEDIATE	Production MONGO_URI in the hosting secret manager	Backend restarts; health, readiness, login, and a database-backed request succeed
3 - HIGH	Any maintenance/admin password previously stored, printed, messaged, or reused	Old password no longer authenticates; replacement is stored only in the approved secret channel
4 - HIGH	Any API token or service key known to have been committed or shared	Provider shows a new key; former key is revoked; deployment uses secret storage
5 - CONFIG	CLIENT_URL and CLIENT_URLS exact production HTTPS origins	Approved frontend works; an unlisted origin is rejected
6 - TEST	Dedicated non-production TEST_MONGO_URI	Skipped auth-cookie database integration test runs without touching production data

Why rotation remains mandatory

Deleting a secret from the latest source does not invalidate the credential and does not erase it from earlier Git commits, local clones, logs, screenshots, or messages. Rotation is the action that makes the old value unusable. A history rewrite may reduce future exposure but is not a substitute for rotation.

Verification evidence and closure criteria

Checks completed locally against the handover code before repository delivery.

SCOPE	COMMAND / CHECK	OBSERVED RESULT
Backend	npm test	103 passed, 0 failed, 1 skipped
Backend source	source credential hygiene regression	No tracked MongoDB URI with embedded credentials; scripts remain environment-only
Backend security	security regression suite	CORS, data retention, regex safety, auth helpers, upload ACL, and related checks pass
Frontend	npm run check	Exit code 0; zero TypeScript errors
Frontend	npm run build	Production Vite build completed successfully

Known verification note

The single skipped backend test is the authentication cookie integration test that requires a dedicated TEST_MONGO_URI. It was not pointed at production. This is an environment-dependent verification item for the client, not a failing test.

Handover acceptance checklist

- Hyderabad backend and frontend branches contain the cited code commits and this report.
- The client rotates the MongoDB Atlas database-user password and updates production MONGO_URI.
- The old MongoDB URI is confirmed unusable.
- Production is restarted and smoke-tested using approved HTTPS origins.
- A dedicated TEST_MONGO_URI is supplied and the previously skipped integration test is run.
- Any other credential known to have been exposed or reused is rotated at its provider.

ENGINEERING CLOSURE

Source remediation and frontend type-check closure are complete. Client-side secret rotation remains mandatory.